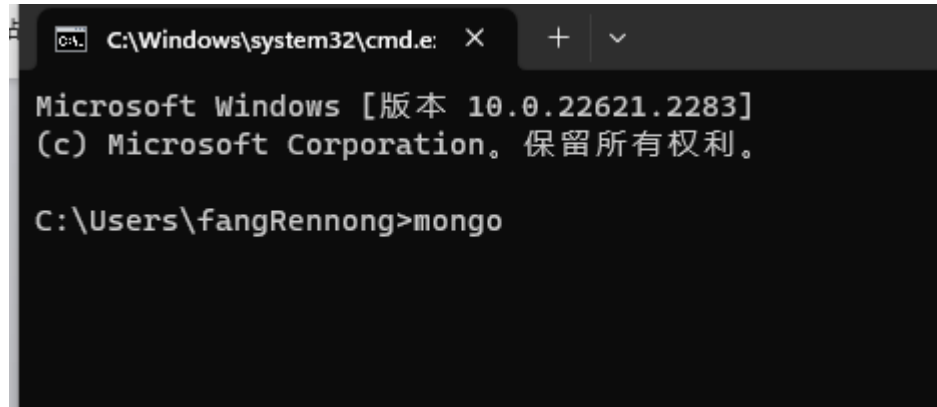


实验八:Mongodb 安全访问控制操作案例

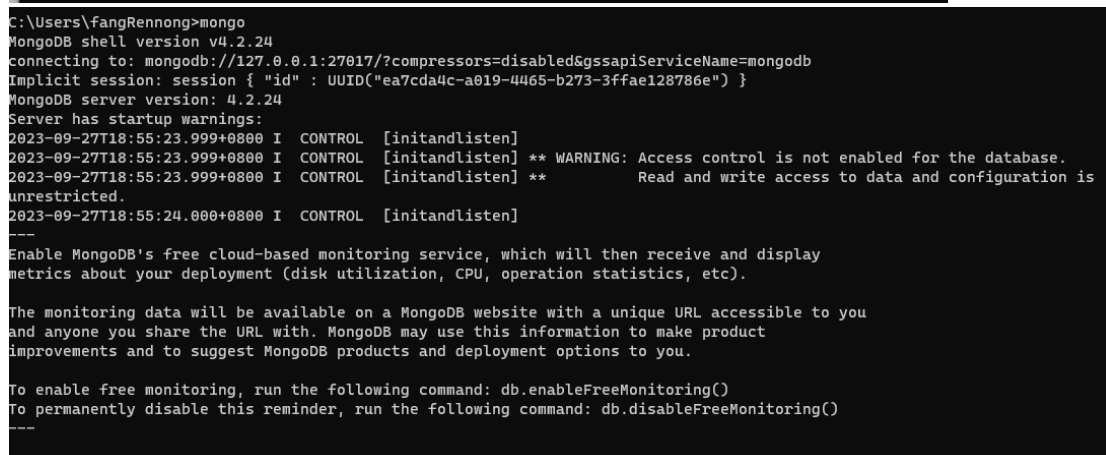
1、新建 mongodb 用户

进入 mongodb shell，并在 admin 数据库中新建用户



```
C:\Windows\system32\cmd.e: X + v
Microsoft Windows [版本 10.0.22621.2283]
(c) Microsoft Corporation。保留所有权利。

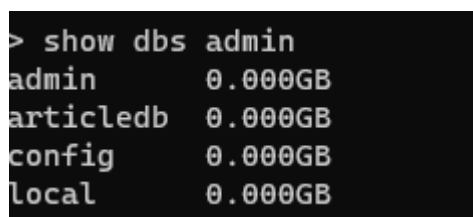
C:\Users\fangRennong>mongo
```



```
C:\Users\fangRennong>mongo
MongoDB shell version v4.2.24
connecting to: mongodb://127.0.0.1:27017/?compressors=disabled&gssapiServiceName=mongodb
Implicit session: session { "id" : UUID("ea7cda4c-a019-4465-b273-3ffae128786e") }
MongoDB server version: 4.2.24
Server has startup warnings:
2023-09-27T18:55:23.999+0800 I CONTROL [initandlisten]
2023-09-27T18:55:23.999+0800 I CONTROL [initandlisten] ** WARNING: Access control is not enabled for the database.
2023-09-27T18:55:23.999+0800 I CONTROL [initandlisten] ** Read and write access to data and configuration is
unrestricted.
2023-09-27T18:55:24.000+0800 I CONTROL [initandlisten]
---
Enable MongoDB's free cloud-based monitoring service, which will then receive and display
metrics about your deployment (disk utilization, CPU, operation statistics, etc).

The monitoring data will be available on a MongoDB website with a unique URL accessible to you
and anyone you share the URL with. MongoDB may use this information to make product
improvements and to suggest MongoDB products and deployment options to you.

To enable free monitoring, run the following command: db.enableFreeMonitoring()
To permanently disable this reminder, run the following command: db.disableFreeMonitoring()
---
```



```
> show dbs admin
admin          0.000GB
articledb      0.000GB
config         0.000GB
local          0.000GB
```

输入: >use admin

>show dbs

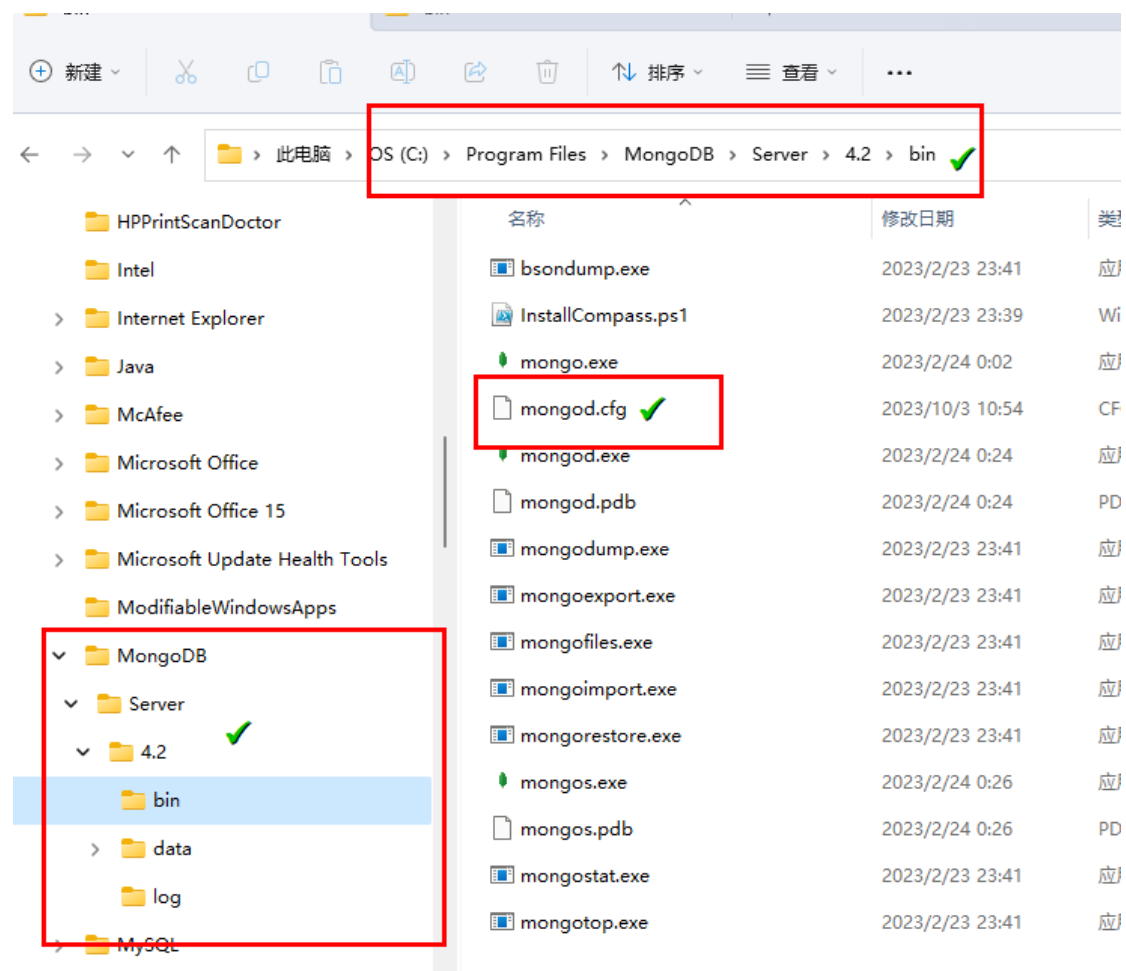
输入:

```
>db.createUser({user:"taotao",pwd:passwordPrompt(),roles:[{role:"userAdminAnyDatabase",db:
"admin"}]})
```

```
local 0.000GB
> use admin
switched to db admin
> show users
> db.createUser({user:"taotaoAdmin",pwd:passwordPrompt(),roles:[{role:"userAdminAnyDatabase",db:"admin"}]})
... 123456
... show users
...
2022-11-06T13:44:34.408+0800 E QUERY [js] uncaught exception: SyntaxError: missing ) after argument list :
@(_shell):2:0
> db.createUser({user:"taotao",pwd:passwordPrompt(),roles:[{role:"userAdminAnyDatabase",db:"admin"}]})
Enter password: [redacted]
Successfully added user: {
  "user": "taotao",
  "roles": [
    {
      "role": "userAdminAnyDatabase",
      "db": "admin"
    }
  ]
}
```

提示输入密码：12345

2、修改配置文件开启权限访问 mongod.conf



```
logAppend: true
path: C:\Program Files\MongoDB\Server\4.2\log\mongod.log

# network interfaces
net:
  port: 27017
  bindIp: 127.0.0.1

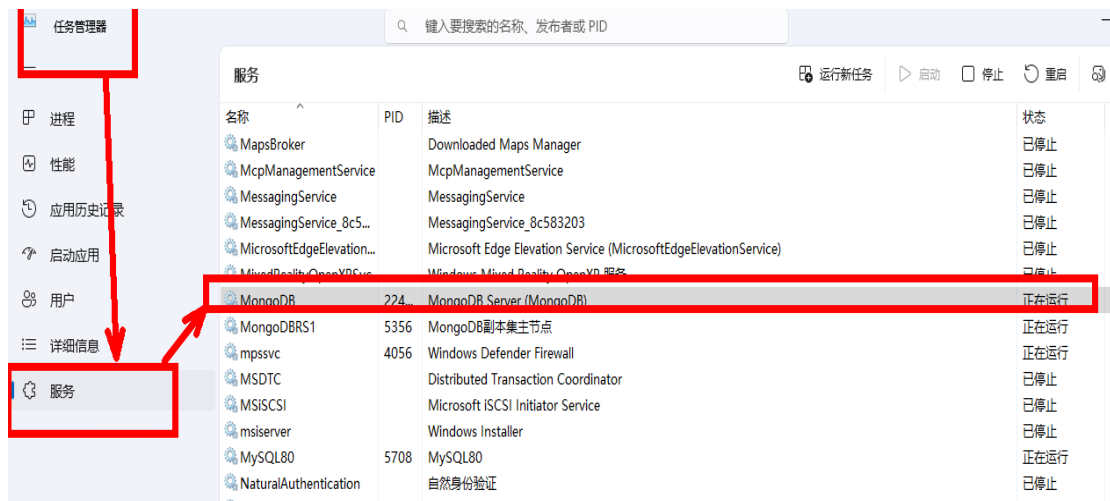
#security:
  authorization: enabled

#operation profiling:

#replication:
```

修改 **mongod.conf** 文件并且保存好

3、重启 mongodb 服务



权限说明

MongoDB数据库的内置角色及相关权限说明

内置角色	权限说明
root	只可以用于admin数据库，该角色具有超级权限
read	可以读取指定数据库中任何数据
readWrite	可以读写指定数据库中任何数据，包括创建、重命名及删除集合
readAnyDatabase	可以读取所有数据库中任何数据（除数据库config和local外）
readWriteAnyDatabase	可以读写所有数据库中任何数据（除数据库config和local外）
dbAdmin	可以读取指定数据库以及对数据库进行清理、修改、压缩、获取统计信息、执行检查等操作
dbAdminAnyDatabase	可以读取任何数据库以及对数据库进行清理、修改、压缩、获取统计信息、执行检查等操作（除数据库config和local外）



CSDN @鬼鬼骑士

MongoDB数据库的内置角色及相关权限说明

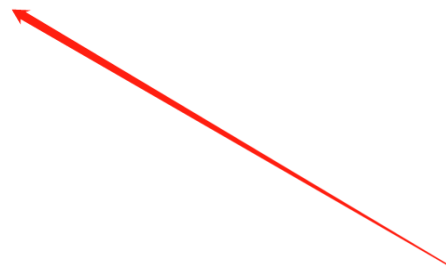
内置角色	权限说明
<u>clusterAdmin</u>	可以对整个集群或数据库系统进行管理操作
userAdmin	允许用户向system.users集合写入，可以对指定数据库进行创建、删除操作和管理用户
userAdminAnyDatabase	只用于admin数据库中，赋予用户所有数据库的 <u>userAdmin</u> 权限

CSDN @鬼鬼骑士

尝试直接访问数据库

数据库为空，因为我们设置了用户权限，必须登录才能正常访问数据库

```
[root@nosql01 ~]# mongo 192.168.121.134:27017
MongoDB shell version v4.2.2
connecting to: mongodb://192.168.121.134:27017/test?compressors=disabled&gssapiServiceName=mongodb
Implicit session: session { "id" : UUID("748d7ddd-5d1b-4440-8a16-033c8aef728d") }
MongoDB server version: 4.2.2
> show dbs
> █
```



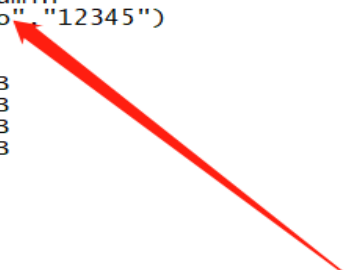
CSDN @鬼鬼骑士

4、直接切换 admin 进行控制，登录用户 taotao

输入：

```
>show dbs
>use admin
>db.auth("taotao","12345")
>db.auth("taotao","12345")
```

```
MongoDB server version: 4.2.2
> show dbs
> use admin
switched to db admin
> db.auth("taotao","12345")
1
> show dbs
admin          0.000GB
articledb      0.000GB
config         0.000GB
local          0.000GB
>
```



CSDN @鬼鬼骑士

5、创建基于管理员用户的“子用户”

创建一个基于 Admin-taotao 的用户 taotaouser1，该用户只有 admin 数据库的 read 权限

```
db.createUser({user:"taotaouser",pwd:"12345",roles:[{role:"read",db:"admin"}]})
```

```

js
> db.createUser({user:"taotaoUser",pwd:"12345",roles:[role:"read",db:"admin"]})
2022-11-06T14:22:27.588+0800 E QUERY [js] uncaught exception: SyntaxError: missing ] after element list :
@shell:1:56
> db.createUser({user:"taotaouser",pwd:"12345",roles:[{role:"read",db:"admin"}]})
Successfully added user: {
  "user" : "taotaouser",
  "roles" : [
    {
      "role" : "read",
      "db" : "admin"
    }
  ]
}
> █

```

CSDN @鬼鬼骑士

检查是否创建成功

输入

>show users

```

js
> show users
{
  "_id" : "admin.taotao",
  "userId" : UUID("8af4b12a-e4b4-48e7-8764-8c56076a..."),
  "user" : "taotao",
  "db" : "admin",
  "roles" : [
    {
      "role" : "userAdminAnyDatabase",
      "db" : "admin"
    }
  ],
  "mechanisms" : [
    "SCRAM-SHA-1",
    "SCRAM-SHA-256"
  ]
}
{
  "_id" : "admin.taotaouser",
  "userId" : UUID("06ebf31d-03c1-4983-973d-e4d13f5a..."),
  "user" : "taotaouser",
  "db" : "admin",
  "roles" : [
    {
      "role" : "read",
      "db" : "admin"
    }
  ],
  "mechanisms" : [
    "SCRAM-SHA-1",
    "SCRAM-SHA-256"
  ]
}
>

```

查看指定用户信息

输入就

```
db.getUser("taotaouser")
```

```
> db.getUser("taotaouser")
{
  "_id" : "admin.taotaouser",
  "userId" : UUID("06ebf31d-03c1-4983-973d-e4d13f!"),
  "user" : "taotaouser",
  "db" : "admin",
  "roles" : [
    {
      "role" : "read",
      "db" : "admin"
    }
  ],
  "mechanisms" : [
    "SCRAM-SHA-1",
    "SCRAM-SHA-256"
  ]
}
```

6、尝试使用子用户进行数据库操作

向 mycollection 集合插入数据

输入

```
>db.mycollection.insert({"a":1,"b":2})
```

权限不足

```
> db.auth("taotaouser","12345")
1
> show dbs
admin 0.000GB
> db.mycollection.insert({"a":1,"b":2})
WriteCommandError({
  "ok" : 0,
  "errmsg" : "not authorized on admin to execute command { insert: \"mycollection\", ordered: true, lsid: { id
  "code" : 13,
  "codeName" : "Unauthorized"
})
>
```

7、使用 admin 用户给 taotaouser 赋予 write 权限

输入>use admin

> db.auth("taotao","12345")

>show collections

>db.grantRolesToUser("taotaouser",[{role:"readWrite",db:"admin"}])

```
>db.grantRolesToUser("taotaouser",[{role:"readWrite",db:"admin"}])
> `db.auth("taotao","12345")
1
> show collections
system.users
system.version
> db.grantRolesToUser("taotaouser",[{role:"readWrite",db:"admin"}])
>
```

8、再次尝试使用 taotaouser 用户添加数据

输入: >db.auth("taotaouser","12345")

>db.mycollection.insert({"a":1,"b":2})

>db.mycollection.find()

写数据成功

```
0
> db.auth("taotaouser","12345")
1
> db
admin
> db.mycollection.insert({"a":1,"b":2})
WriteResult({ "nInserted" : 1 })
> show dbs
```

```
> show dbs
admin 0.000GB
> db.mycollection.insert({"a":1,"b":2})
WriteResult({ "nInserted" : 1 })
```



```

> db.grantRolesToUser( taotaouser ,[{role: readwrite ,c
> db.auth("taotaouser","12345")
1
> show collections
> show dbs
admin 0.000GB
> use admin
switched to db admin
> db.mycollection.insert({"a":1,"b":2})
WriteResult({ "nInserted" : 1 })
> show collections
mycollection

```

CSDN @鬼鬼骑士

9、其他权限、功能赋予或删除

修改用户信息

使用管理员用户itcastAdmin将普通用户itcastUser的readWrite角色修改为readAnyDatabase。

```
db.updateUser("itcastUser", {roles:[{role:"read",db:"admin"},
{role:"readAnyDatabase",db:"admin"}]})
```

CSDN @鬼鬼骑士

删除用户角色

使用管理员用户itcastAdmin删除普通用户itcastUser中的readAnyDatabase角色。

```
db.revokeRolesFromUser("itcastUser", [{role:"readAnyDatabase", db:"admin"}])
```

修改用户信息

使用管理员用户itcastAdmin修改普通用户itcastUser的密码，修改为itcastuser。

```
db.changeUserPassword("itcastUser", "itcastuser")
```

CSDN @鬼鬼骑士

删除用户

使用管理员用户itcastAdmin删除普通用户itcastUser。

```
db.dropUser("itcastUser")
```

查看用户itcastUser是否删除成功。

```
show users
```

CSDN @鬼鬼骑士

问题（多个 role，代表担任多个角色）

表示此用户既可以读，又可以读写

```
192.168.121.134 (user_mongo) - SecureCRT
文件(F) 编辑(E) 查看(V) 选项(O) 传输(T) 脚本(S) 工具(I) 窗口(W) 帮助(H)
192.168.121.134 (user_mongo) x
{
  "userId" : UUID("293ed30e-8d0b-4891-b97c-3ef895f217e"),
  "user" : "itcastAdmin",
  "db" : "admin",
  "roles" : [
    {
      "role" : "userAdminAnyDatabase",
      "db" : "admin"
    }
  ],
  "mechanisms" : [
    "SCRAM-SHA-1",
    "SCRAM-SHA-256"
  ]
},
{
  "_id" : "admin.itcastUser",
  "userId" : UUID("a52d6e39-44e1-4971-90d5-5a92a810761"),
  "user" : "itcastUser",
  "db" : "admin",
  "roles" : [
    {
      "role" : "read",
      "db" : "admin"
    },
    {
      "role" : "readWrite",
      "db" : "admin"
    }
  ],
  "mechanisms" : [
    "SCRAM-SHA-1",
    "SCRAM-SHA-256"
  ]
}
}
```

SSH2: AES-256-CTR 37, 3 37行, 61列 Linux

CSDN @鬼鬼骑士